

Relatório de Segurança – FPConnect RCA Copilot

Data: 2026-04-05

Escopo: API (backend), Web (Next.js), Mobile (Expo/React Native)

Metodologia

- Auditoria automatizada de dependências Python (`pip-audit`).
- Auditoria automatizada de dependências Node (`npm audit --omit=dev`).
- Verificações de qualidade/execução: `pytest -q`, `npm run lint`, `npm run doctor`.
- Revisão manual de configuração de autenticação/CORS e endurecimento da API.

Vulnerabilidades identificadas e correções aplicadas

API (Python)

- Dependências vulneráveis identificadas inicialmente em `python-jose` e `starlette` (transitiva via FastAPI).
- Correções:
 - Migração de `python-jose` para `PyJWT[crypto]` em versão corrigida.
 - Upgrade de `fastapi`, `pydantic` e `pydantic-settings` para versões atuais compatíveis.
 - Inclusão de `iat` e `nbf` no JWT para reduzir abuso temporal de token.
- Status final: `pip-audit` sem vulnerabilidades conhecidas.

Web (Next.js)

- Dependência vulnerável: `next` em versão afetada por múltiplos advisories moderados.
- Correção: upgrade para `next@15.5.14` e `eslint-config-next@15.5.14`.
- Status final: `npm audit --omit=dev` sem vulnerabilidades.

Mobile (Expo)

- Dependências transitivas vulneráveis detectadas por `npm audit`.
- Correção: execução de `npm audit fix` com atualização do lockfile.
- Status final: `npm audit --omit=dev` sem vulnerabilidades.

Hardening adicional de aplicação

- CORS alterado de permissivo global (`\*`) para allowlist explícita via configuração.
- Métodos e headers CORS limitados para mínimo necessário.
- Validação de `SECRET\_KEY` reforçada (tamanho mínimo e bloqueio de segredo padrão fora de desenvolvimento).

Evidências (comandos executados)

- `cd apps/api && pip-audit -r requirements.txt`
- `cd apps/api && pytest -q`
- `cd apps/web && npm audit --omit=dev`
- `cd apps/web && npm run lint`
- `cd apps/mobile && npm audit --omit=dev`
- `cd apps/mobile && npm run doctor`

Riscos remanescentes / observações

- `expo-doctor` reportou:
 - falhas de validação de diretório por resposta de rede/proxy;
 - dependência nativa duplicada (`expo-font`) em árvore transitiva.
- Essas observações não bloquearam correções de CVEs reportadas por `npm audit`, mas recomendando acompanhamento contínuo em pipeline CI.

Conclusão

As vulnerabilidades detectadas por scanners automatizados no escopo atual foram mitigadas com sucesso. Recomenda-se manter rotina de auditoria periódica e atualização contínua de dependências.